

FIAP × FORD · CHALLENGE

Sprint 3 — Cybersecurity DevSecOps

Ford Ranger Raptor · Desafio 01: Inteligência Competitiva Automotiva

Entrega: Pipeline DevSecOps Integrado · Segurança em Código e Infraestrutura · Observabilidade, Monitoramento e Resposta · Compliance, Riscos e Segurança Contínua

Repositório: https://github.com/VictorMLCapp/Challenge_Mobile

Pipeline: https://github.com/VictorMLCapp/Challenge_Mobile/actions/runs/3635988451

Victor Mattenhauer Lopes Capp	RM 555753
Artur Alves Tenca	RM 555171
Igor Brunelli Ralo	RM 555035
João Pedro Signor Avelar	RM 558375
Roger Cardoso Ferreira	RM 557230

São Paulo · 27/09/2026

Sumário

- 0. Contexto e arquitetura — Desafio 01, API criada nesta sprint, app mobile
- 1. Atividade 1 — Pipeline DevSecOps Integrado (peso 3,0) — desenho, etapas, riscos, execução real
- 2. Atividade 2 — Segurança em Código e Infraestrutura (peso 2,5) — criptografia local, hardening de API, RBAC, MQTT/TLS, IaC
- 3. Atividade 3 — Observabilidade, Monitoramento e Resposta (peso 2,0) — logs, métricas, alertas, dashboard, incidentes
- 4. Atividade 4 — Compliance, Riscos e Segurança Contínua (peso 2,5) — STRIDE, OWASP ASVS/API/Mobile, LGPD, rotinas
- 5. Checklist de conformidade
- 6. Como reproduzir as evidências

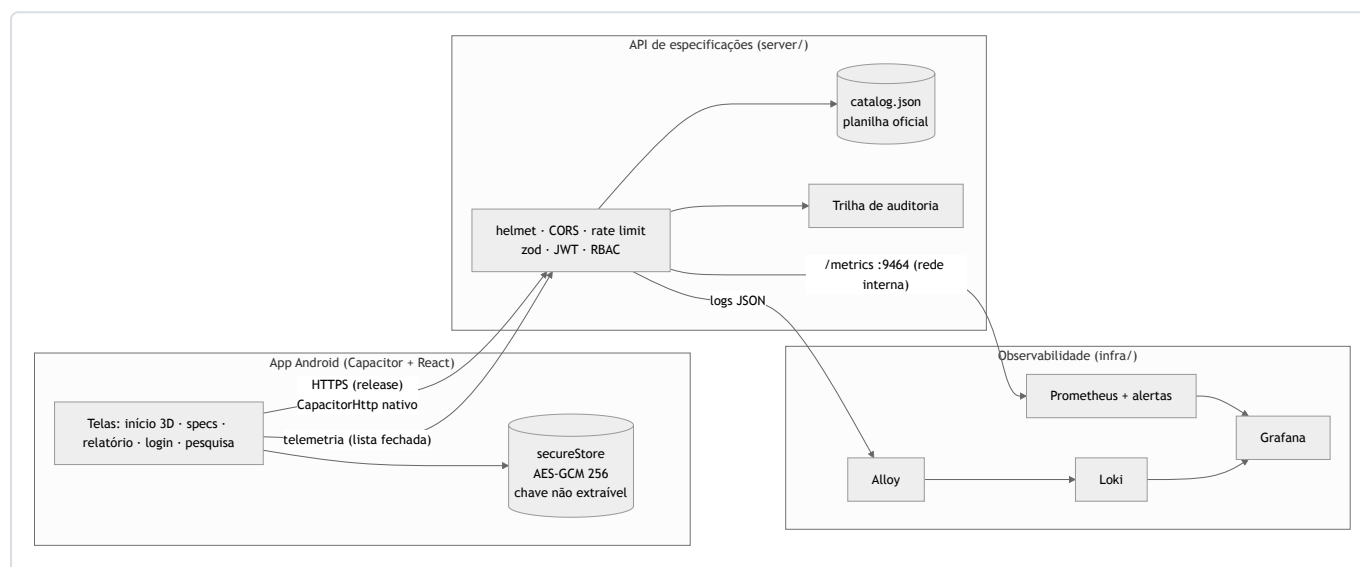
Todos os trechos de código citados estão no repositório. Os prints foram capturados contra o app e a API em execução, e as saídas de ferramentas são reais (execução local e GitHub Actions). O plano detalhado de resposta a incidentes está em `docs/cybersecurity/RESPOSTA_A_INCIDENTES.md`.

0. Contexto e arquitetura

O Desafio 01 pede uma ferramenta que receba **marca, modelo, versão e uma lista livre de atributos** e devolva uma **lista padronizada de especificações**, sempre no mesmo formato, deixando explícito o que não existe. A validação é feita com a **Ford Ranger Raptor**.

Antes desta sprint, o repositório era só o app (React + Vite + react-three-fiber, empacotado como APK com Capacitor), com os dados fixos em `src/data/ranger.json` e **sem backend**. Por isso não havia onde aplicar autenticação, rate limit, JWT ou RBAC. Nesta sprint:

- criamos a **API de especificações** (`server/` , Node 22 + Express 5), que implementa o próprio Desafio 01 a partir da planilha oficial `FIAP-Ford - Data sheet_Desafio_01_v02.xlsx` (gerador: `server/scripts/build_catalog.py`) e da ficha da Raptor do app;
- o **app mobile** ganhou login e a tela **Pesquisar concorrência**, que consomem a API;
- toda a segurança foi aplicada nas duas pontas e automatizada no pipeline.



Fluxo principal (Desafio 01): `POST /api/specs/search`

```
{ "marca": "Ford", "modelo": "Ranger", "versao": "Raptor",  
  "atributos": ["Potência", "Torque", "Teto Solar Elétrico", "Autonomia em Marte"] }
```

```
{  
  "encontrado": true,  
  "veiculo": { "id": "ford-ranger-raptor-3-0-v6", "marca": "Ford", "modelo": "Ranger", "versao": "Raptor  
3.0 V6", "fonte": "src/data/ranger.json (ficha exibida no app)" },  
  "totalAtributos": 4, "disponiveis": 2, "naoDisponiveis": 2,  
  "especificacoes": [  
    { "atributo": "Potência", "valor": 397, "unidade": "cv", "categoria": "Engine & Transmission",  
      "status": "DISPONIVEL" },  
    { "atributo": "Torque", "valor": 583, "unidade": "Nm", "categoria": "Engine & Transmission",  
      "status": "DISPONIVEL" },  
    { "atributo": "Teto Solar Elétrico", "valor": null, "unidade": null, "categoria": null, "status":  
      "NAO_DISPONIVEL" },  
    { "atributo": "Autonomia em Marte", "valor": null, "unidade": null, "categoria": null, "status":  
      "NAO_DISPONIVEL" }  
  ]  
}
```

O teste `server/test/specs.test.js` confirma que as **18 especificações da ficha da Raptor voltam todas como DISPONIVEL**. O app mostra o mesmo resultado na tela, pelo botão “Usar ficha da Ranger Raptor”.

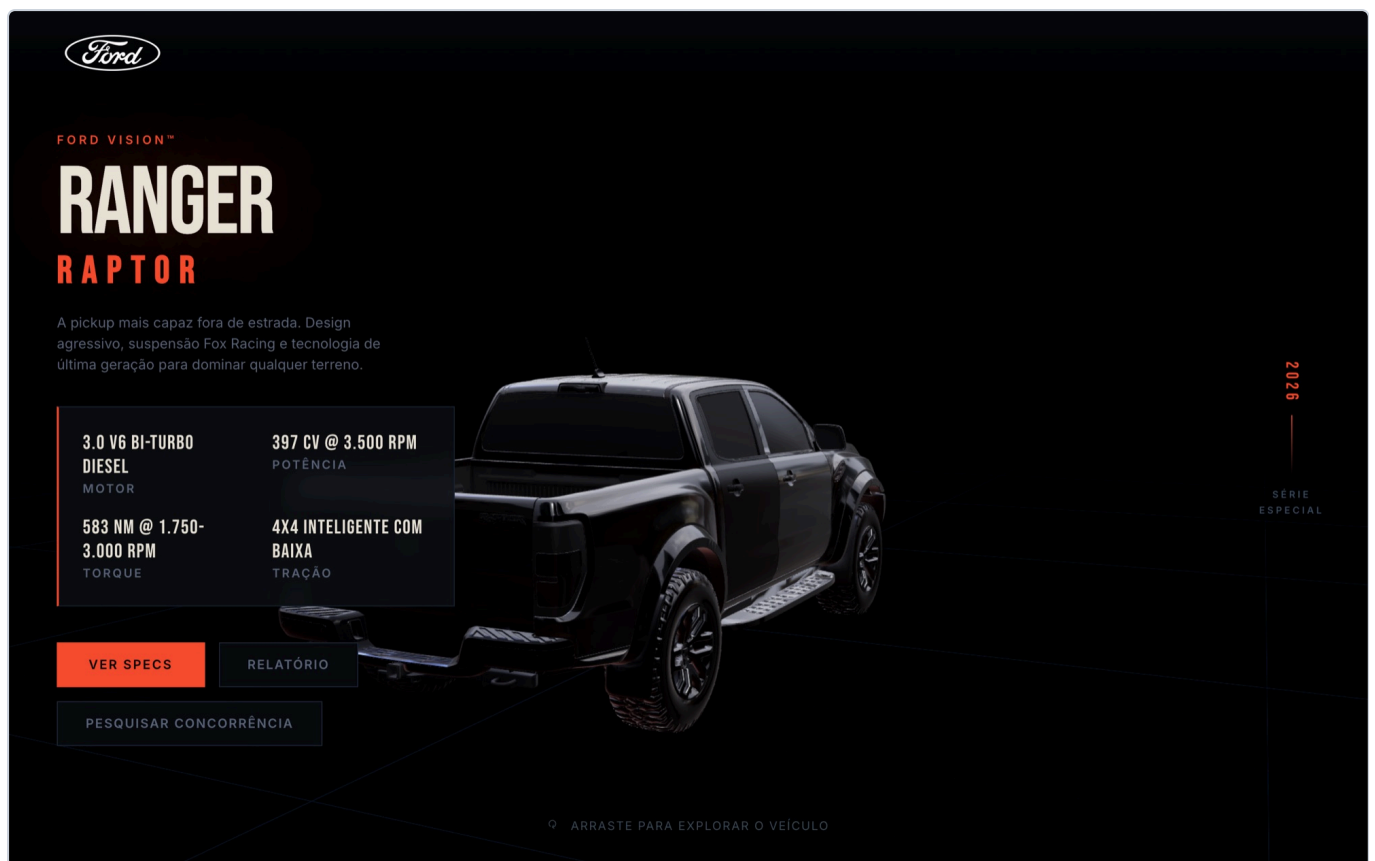


Figura 1 — App Ford Ranger Raptor (modelo 3D) com o novo acesso “Pesquisar concorrência”.

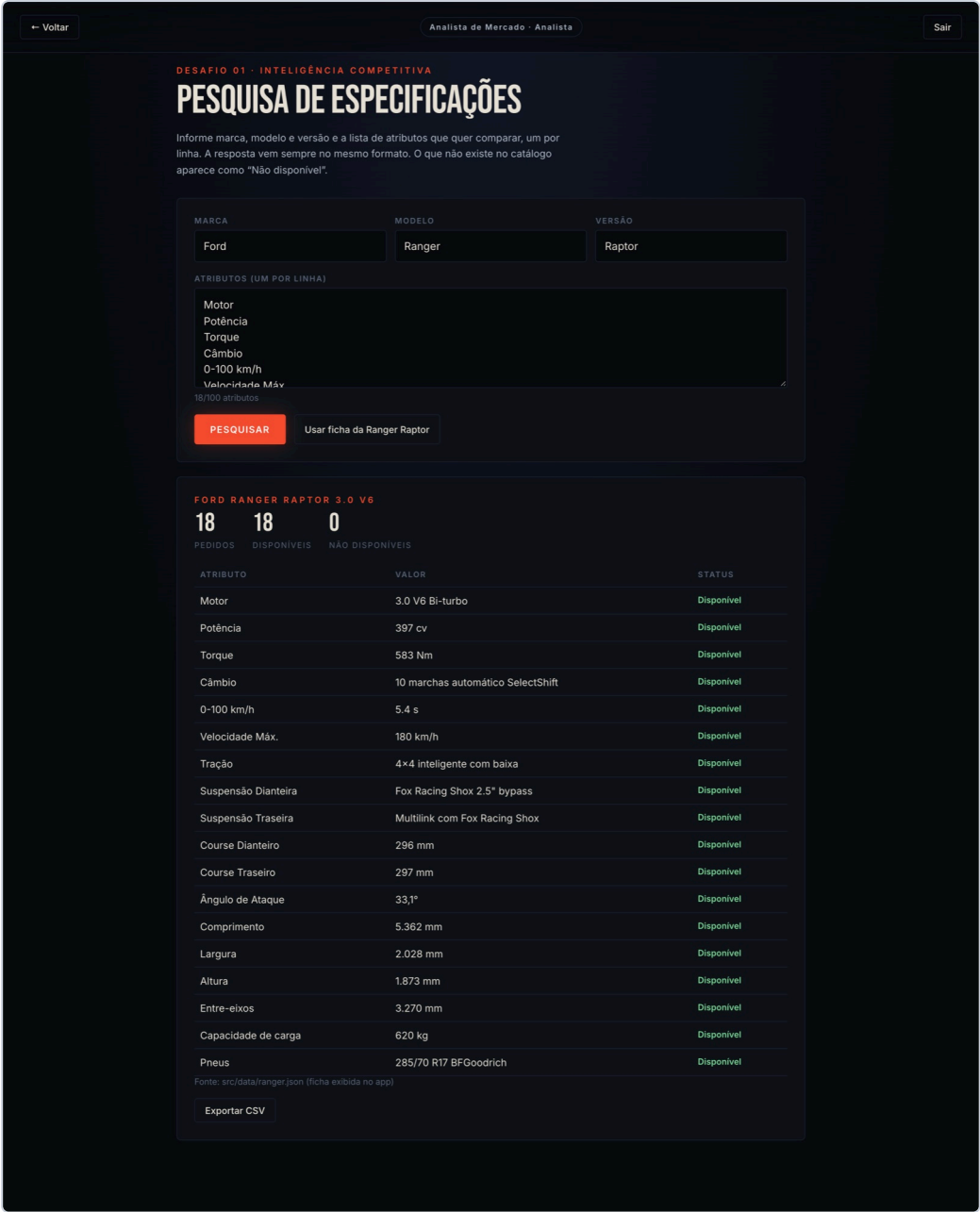


Figura 2 — Desafio 01 no app: ficha da Ranger Raptor com 18/18 especificações disponíveis (perfil ANALISTA).

Voltar

Analista de Mercado · Analista

Sair

DESAFIO 01 · INTELIGÊNCIA COMPETITIVA

PESQUISA DE ESPECIFICAÇÕES

Informe marca, modelo e versão e a lista de atributos que quer comparar, um por linha. A resposta vem sempre no mesmo formato. O que não existe no catálogo aparece como "Não disponível".

MARCA

Modelo

VERSÃO

Ford

Ranger

Raptor

ATRIBUTOS (UM POR LINHA)

Potência

Torque

Teto Solar Elétrico

Autonomia em Marte

4/100 atributos

PESQUISAR

Usar ficha da Ranger Raptor

FORD RANGER RAPTOR 3.0 V6

4

2

2

PEDIDOS

DISPONÍVEIS

NÃO DISPONÍVEIS

ATRIBUTO	VALOR	STATUS
Potência	397 cv	Disponível
Torque	583 Nm	Disponível
Teto Solar Elétrico	Não disponível	Não disponível
Autonomia em Marte	Não disponível	Não disponível

Fonte: src/data/ranger.json (ficha exibida no app)

Exportar CSV

Figura 3 — Mesmo formato de saída com atributos inexistentes explicitados como “Não disponível”.



Figura 4 — App no celular (390×844).

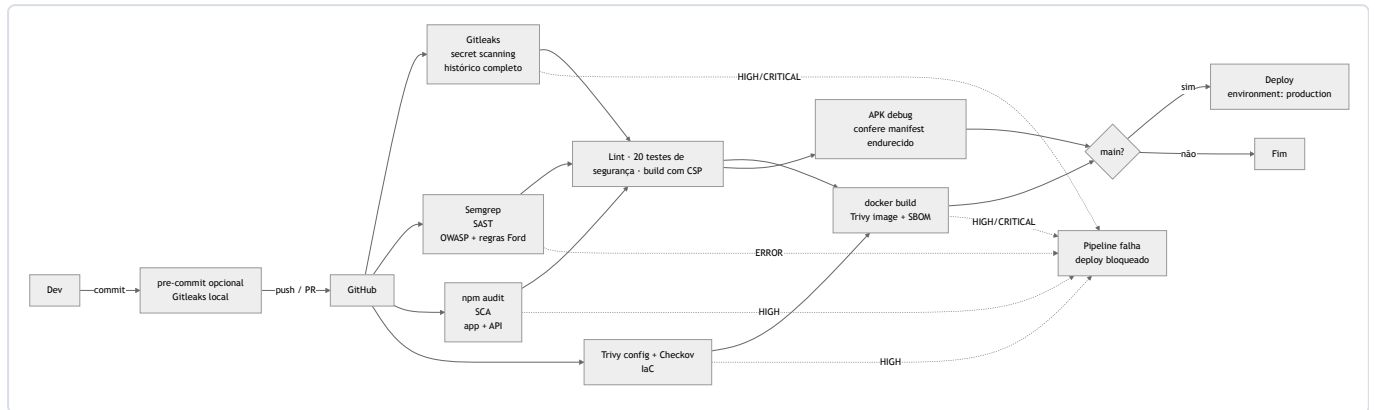


Figura 5 — Resultado da pesquisa no celular.

1. Atividade 1 — Pipeline DevSecOps Integrado (peso 3,0)

Arquivo: `.github/workflows/devsecops.yml` (GitHub Actions)

1.1 Desenho do pipeline



Gatilhos: push em `main` / `develop`, todo Pull Request para `main`, execução semanal (segunda, 06h UTC), para pegar CVEs novas em dependências que não mudaram, e disparo manual.

Regra de bloqueio: qualquer achado HIGH/CRITICAL (ou ERROR no Semgrep) falha o job. O job `deploy` depende de todos os outros (`needs`) e só roda em `main`, dentro do `environment: production`, que pode exigir aprovação manual.

1.2 Etapas e riscos reduzidos

#	Etapas	Ferramenta	O que faz no projeto	Risco reduzido
1	Secret scanning	GitLeaks v8.30.1 (<code>.gitleaks.toml</code>)	Varre todo o histórico (<code>fetch-depth: 0</code>) com as regras padrão + regra <code>ford-jwt-secret</code>	Token, senha ou chave publicada no Git, inclusive em commit antigo já “apagado”
2	SAST	Semgrep 1.178.0	Rulesets <code>p/owasp-top-ten</code> , <code>p/javascript</code> , <code>p/react</code> , <code>p/nodejsscan</code> , <code>p/jwt</code> , <code>p/secrets</code> + 6 regras próprias (<code>.semgrep/ford-rules.yml</code>)	Injeção, XSS, JWT inseguro, segredo no código, rota de escrita sem RBAC, token em texto puro no storage, URL <code>http:// remota</code>
3	SCA	npm audit (app e API, em matriz) + Dependabot	Falha em HIGH; Dependabot abre PR semanal para npm (app e API), Gradle, Docker e Actions, com <code>cooldown</code> de 7 dias	Biblioteca de terceiros com CVE conhecida; pacote malicioso recém-publicado
4	Testes	<code>node:test</code> + <code>supertest</code> (20 testes)	Autenticação, logout, rate limit, JWT forjado/ <code>alg:none</code> /expirado, revogação, matriz RBAC, validação, headers, CORS	Regressão que desliga um controle de segurança sem ninguém perceber
5	Build	Vite	Build web com CSP injetada; o job confere que ela está no <code>dist/index.html</code>	Build que vai para produção sem CSP
6	IaC	Trivy config + Checkov	Dockerfile, <code>docker-compose.yml</code> , manifesto Kubernetes e o próprio workflow	Container root, sem limite de recurso, segredo em variável, action não fixada
7	Container	Trivy image + SBOM CycloneDX	Varre a imagem da API (SO + pacotes npm) e publica o SBOM como artefato	Imagem com pacote vulnerável; falta de inventário de componentes

#	Etapa	Ferramenta	O que faz no projeto	Risco reduzido
8	Mobile	Gradle assembleDebug	Gera o APK e confere no manifest mesclado <code>allowBackup="false"</code> e <code>networkSecurityConfig</code>	APK que perde o hardening por mudança de config
9	Deploy	Gate needs:	Só roda com todos os gates verdes	Deploy de versão insegura

Recursos de segurança ativos no repositório GitHub: alertas do Dependabot, *Dependabot security updates* (PR automático de correção), **secret scanning com push protection** (o GitHub recusa um push que contenha token conhecido) e *private vulnerability reporting* (canal do SECURITY.md).

Proteção da própria esteira (supply chain do CI):

- toda `uses:` é fixada por **SHA de commit** (ex.: `actions/checkout@3d3c42e... # v7.0.1`), não por tag móvel. Uma tag comprometida não troca o código executado;
- `permissions: contents: read` no workflow inteiro (menor privilégio do `GITHUB_TOKEN`);
- `concurrency` cancela execuções velhas da mesma branch.

1.3 Resultados executados (evidências em `docs/cybersecurity/evidencias/`)

Ferramenta	Resultado	Arquivo
Semgrep (216 regras, mesmo comando do CI)	0 achados bloqueantes após triagem (ver 1.4)	<code>semgrep.txt</code>
Checkov	Kubernetes 91 ok / 0 falhas , Dockerfile 65 / 0 , GitHub Actions 188 / 0 (local e no CI)	<code>checkov.txt</code> , <code>iac-ci.txt</code>
Gitleaks (CI)	52 commits varridos, no leaks found	<code>gitleaks-ci.txt</code>
Trivy image (CI)	0 vulnerabilidades no SO (alpine 3.24.2) e nos 112 pacotes npm da imagem	<code>trivy-image-ci.txt</code>
Build do APK (CI)	<code>assembleDebug</code> ok; manifest mesclado com <code>allowBackup="false"</code> e <code>networkSecurityConfig</code>	job <i>Build Android</i>
npm audit — antes (branch <code>main</code>)	11 vulnerabilidades: 5 HIGH , 5 moderadas, 1 baixa (vite, postcss, nanoid, brace-expansion, browserslist, fflate...)	<code>npm-audit-antes.txt</code>
npm audit — depois (app)	0 HIGH/CRITICAL; restam 3 moderadas em <code>@capacitor/cli</code> → <code>xcode</code> → <code>uuid</code> (risco aceito, ver 4.1)	<code>npm-audit-app.txt</code>
npm audit — API	0 vulnerabilidades	<code>npm-audit-server.txt</code>
Testes da API	20/20 passando	<code>testes-api.txt</code>

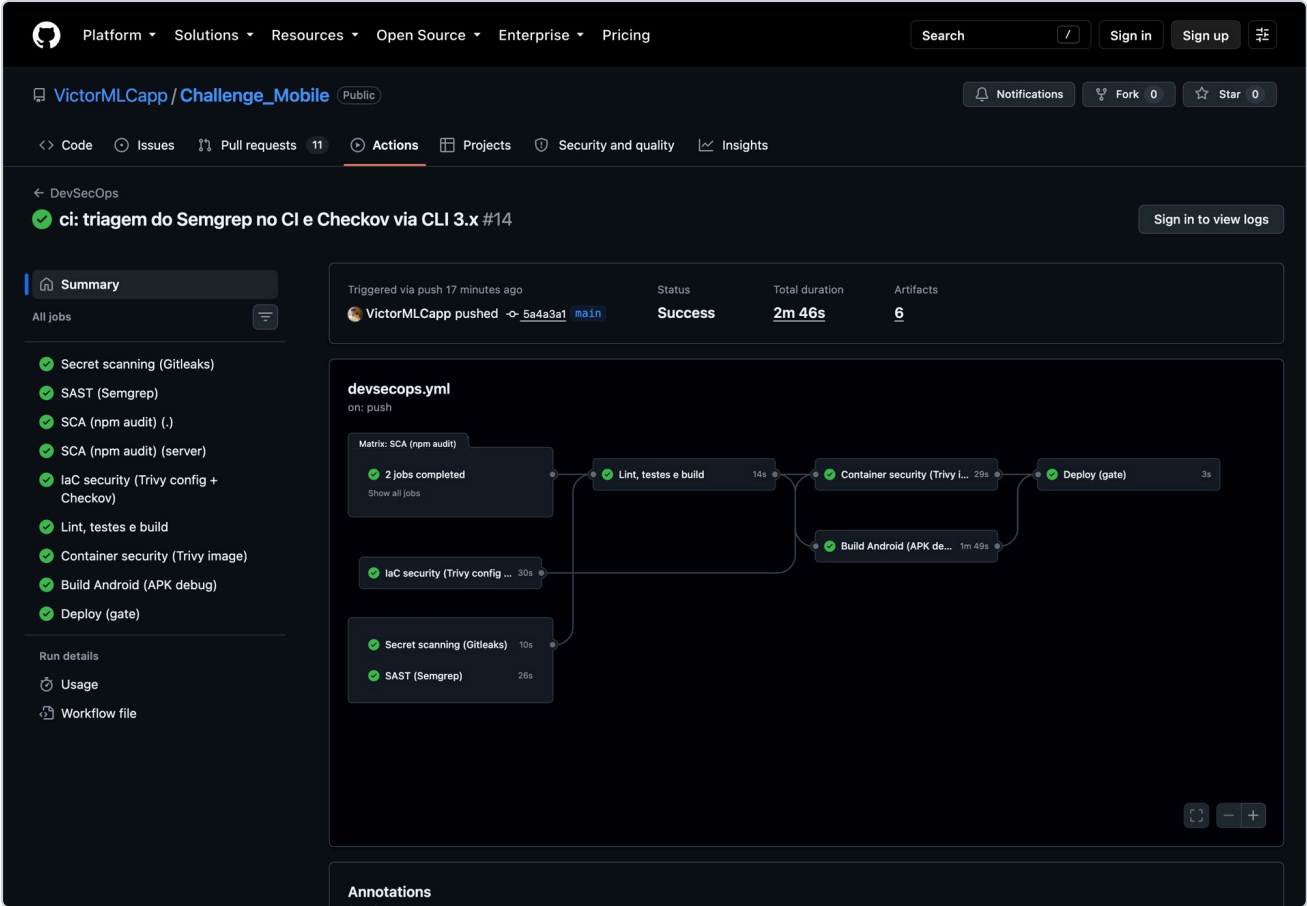


Figura 6 — Execução do pipeline DevSecOps no GitHub Actions: 9 jobs aprovados, status Success.

GitLeaks (CI) — secret scanning do histórico completo

11:48PM INF 52 commits scanned.
11:48PM INF scanned ~1175007 bytes (1.18 MB) in 673ms
11:48PM INF no leaks found

Trivy image (CI) — imagem da API

Report Summary

Target	Type	Vulnerabilities
Secrets		
ford-specs-api:5a4a3a1890526db58b2a4b96b63f1e4504d97a69 (alpine 3.24.2)	alpine	0
app/node_modules/@opentelemetry/api/package.json	node-pkg	0
... (112 pacotes npm da imagem, todos com 0 vulnerabilidades) ...		

Legend:

Checkov (CI) — IaC

```
kubernetes scan results:
Passed checks: 91, Failed checks: 0, Skipped checks: 1
dockerfile scan results:
Passed checks: 65, Failed checks: 0, Skipped checks: 0
github_actions scan results:
Passed checks: 188, Failed checks: 0, Skipped checks: 0
```

npm audit — ANTES (branch main original)

```
npm audit ANTES da correção (branch main):
@babel/core: low - @babel/core: Arbitrary File Read via sourceMappingURL Comment
@capacitor/cli: moderate - xcode
baseline-browser-mapping: moderate - baseline-browser-mapping process termination on invalid input
causes denial of service
brace-expansion: high - brace-expansion: DoS via exponential-time expansion of consecutive non-
expanding {} groups, brace-expansion: DoS via unbounded expansion length causing an out-of-memory process
crash, brace-expansion: DoS via unbounded intermediate arrays, bypassing the CVE-2026-14257 mitigation
browserslist: high - Browserslist: Unbounded memory growth (no cache eviction) via distinct query
results, leading to eventual OOM, Browserslist: Uncaught crash / prototype write via untrusted
browserslist-stats.json custom stats (normalizeStats)
fflate: moderate - fflate unzipSync can enter an infinite loop when parsing malformed ZIP64 archives,
fflate unzipSync can enter an infinite loop when parsing malformed ZIP64 archives
nanoid: high - nanoid: non-secure generators can loop indefinitely with negative size, nanoid: custom
generators can loop indefinitely when size is zero
postcss: high - PostCSS: incomplete fix of GHSA-6g55-p6wh-862q - attacker-controlled sourceMappingURL
reads arbitrary .map files when `from` is unset, PostCSS: Path Traversal in Previous Source Map Auto-
Loading (sourceMappingURL) leads to Arbitrary .map File Disclosure
uuid: moderate - uuid: Missing buffer bounds check in v3/v5/v6 when buf is provided
vite: high - launch-editor: NTLMv2 hash disclosure via UNC path handling on Windows, vite:
`server.fs.deny` bypass on Windows alternate paths
xcode: moderate - uuid
total: {'info': 0, 'low': 1, 'moderate': 5, 'high': 5, 'critical': 0, 'total': 11}
```

npm audit — DEPOIS (API)

```
found 0 vulnerabilities
```

Semgrep — gate do CI (--severity ERROR --error)

```
• Findings: 0 (0 blocking)
• Rules run: 216
• Targets scanned: 139
Ran 216 rules on 139 files: 0 findings.
```

1.4 Triagem dos achados do Semgrep

Semgrep trouxe 10 achados na primeira execução local e mais 1 na primeira execução do CI. Nenhum foi ignorado sem análise:

Achado	Local	Decisão
dependabot- missing-cooldown (5x)	.github/dependabot.y ml	Corrigido: cooldown.default-days: 7 em todos os ecossistemas

Achado	Local	Decisão
<code>regex_injection_dos</code>	<code>server/src/routes/sp ecs.js</code>	Falso positivo: <code>normalize()</code> usa só regex fixas e lineares, e o schema já limita cada campo a 120 caracteres. Justificado no código + <code>nosemgrep</code>
<code>regex_dos</code>	<code>server/src/app.js</code> (X-Request-Id)	Falso positivo: classe fixa <code>{36}</code> , sem quantificador aninhado. Adicionado também o teste de tamanho antes da regex
<code>exported_activity</code>	<code>AndroidManifest.xml</code>	Aceito: a Activity de launcher (MAIN/LAUNCHER) precisa ser exportada. Não há outros componentes exportados
<code>helmet_header_*</code> (info)	app de métricas	Corrigido: <code>helmet()</code> também no servidor de <code>/metrics</code>
<code>node_secret</code> (achado no CI , 1ª execução)	<code>server/src/config.js</code> (leitura do <code>JWT_SECRET_FILE</code>)	Falso positivo: o valor vem do arquivo montado em runtime. Justificado + <code>nosemgrep</code> . A 1ª execução do pipeline falhou por causa disso , e o gate funcionou como esperado
<code>checkov-action</code> puxando checkov 2.0.930	workflow	Corrigido: trocado pela CLI <code>checkov==3.3.20</code> fixada

Platform Solutions Resources Open Source Enterprise Pricing Search Sign in Sign up

VictorMLCapp / Challenge_Mobile Public Notifications Fork 0 Star 0

Code Issues Pull requests 11 Actions Projects Security and quality Insights

Commits

main All users All time

Commits on Sep 27, 2026

- docs: resultados do pipeline no GitHub Actions (9/9) e evidências do CI** Victor Capp and claude committed 12 minutes ago · 4 / 9 `b3fbd3d`
- ci: triagem do Semgrep no CI e Checkov via CLI 3.x** Victor Capp and claude committed 17 minutes ago · 9 / 9 `5a4a3a1`
- docs: aponta referências para VictorMLCapp/Challenge_Mobile** Victor Capp and claude committed 21 minutes ago · 3 / 9 `8b80d3c`
- docs: documento da Sprint 3 de Cybersecurity, resposta a incidentes e evidências** Victor Capp and claude committed 27 minutes ago `3ed3102`
- feat(infra): Dockerfile endurecido, compose com Prometheus/Loki/Alloy/Grafana e manifesto K8s** Victor Capp and claude committed 27 minutes ago `c6e0e82`
- ci: pipeline DevSecOps com Gitleaks, Semgrep, npm audit, Trivy, Checkov e Dependabot** Victor Capp and claude committed 27 minutes ago `9c43bea`
- fix(deps): npm audit fix (5 HIGH -> 0 HIGH)** Victor Capp and claude committed 27 minutes ago `1a8f4e2`
- fix(android): network security config, backup desligado e R8 no release** Victor Capp and claude committed 27 minutes ago `1c14a3b`
- feat(mobile): login, pesquisa de concorrência e criptografia local do token** Victor Capp and claude committed 27 minutes ago `3051fe6`

Figura 7 — Commits das melhorias de segurança no repositório (histórico público).

2. Atividade 2 — Segurança em Código e Infraestrutura (peso 2,5)

2.1 Criptografia local (mobile) — `src/services/secureStore.js`

O token de sessão **nunca** fica em texto puro no `localStorage` da WebView. É cifrado com **AES-GCM 256**. A chave é gerada no aparelho como `CryptoKey` **não extraível** e guardada no IndexedDB, então o JavaScript usa a chave mas não consegue ler os bytes dela.

```
const key = await crypto.subtle.generateKey({ name: 'AES-GCM', length: 256 }, false, ['encrypt', 'decrypt'])
// ...
const iv = crypto.getRandomValues(new Uint8Array(12))
const cipher = await crypto.subtle.encrypt({ name: 'AES-GCM', iv }, await getKey(), plain)
localStorage.setItem(PREFIX + name, JSON.stringify({ v: 1, iv: toB64(iv), ct: toB64(cipher) })))
```

Se alguém adultera o valor salvo, a autenticação do GCM falha e o item é descartado. **Verificado no navegador:** depois do login, o único item salvo é `ford.sec.session = {"v":1,"iv":"","ct":""}`, sem `eyJ...` (JWT) legível.

Evidência — conteúdo do armazenamento do app após o login (coletado no navegador)

```
{
  "chaves": [
    "ford.sec.session"
  ],
  "valor": "
{\\\"v\\\":1,\\\"iv\\\":\\\"jFXqndi0svsBpkY\\\",\\\"ct\\\":\\\"begYgy/hUyxuoHwjQQipF5tQzeP9zdtzBSZGebppcnYz0cM6D7/LDIbYcVUJZX0RLHJdBh8tnhGjuWy/BJ+...\\\"}",
  "contemJWT": false
}
```

A regra Semgrep `ford-token-in-plain-storage` bloqueia no CI qualquer `localStorage.setItem` de token/sessão fora desse módulo.

Senhas no servidor: bcrypt custo 12 (`server/scripts/create-user.js`). O arquivo de usuários só aceita hash bcrypt: um `passwordHash` em texto puro faz o boot falhar (`server/src/auth/users.js`).

2.2 Hardening de API

Validação de entrada (zod, `server/src/routes/specs.js`). Os objetos são `strictObject`: campo desconhecido (ex.: `"role": "ADMIN"`) é rejeitado, o que bloqueia *mass assignment*.

```
export const searchSchema = z.strictObject({
  marca: safeText(40),
  modelo: safeText(60),
  versao: safeText(80),
  atributos: z.array(safeText(120)).min(1).max(100)
  .refine((list) => new Set(list.map((a) => a.toLowerCase())).size === list.length, 'atributos repetidos'),
})
// safeText: trim, tamanho, sem caracteres de controle nem < >
```

Também há body limitado a **16 kB** (413 acima disso), JSON malformado vira **400** sem stack trace, e o handler de erro nunca devolve mensagem interna. O teste cobre `<script>`, operador NoSQL `{ "$ne": null }`, lista vazia, 101 atributos, duplicados e campo extra.

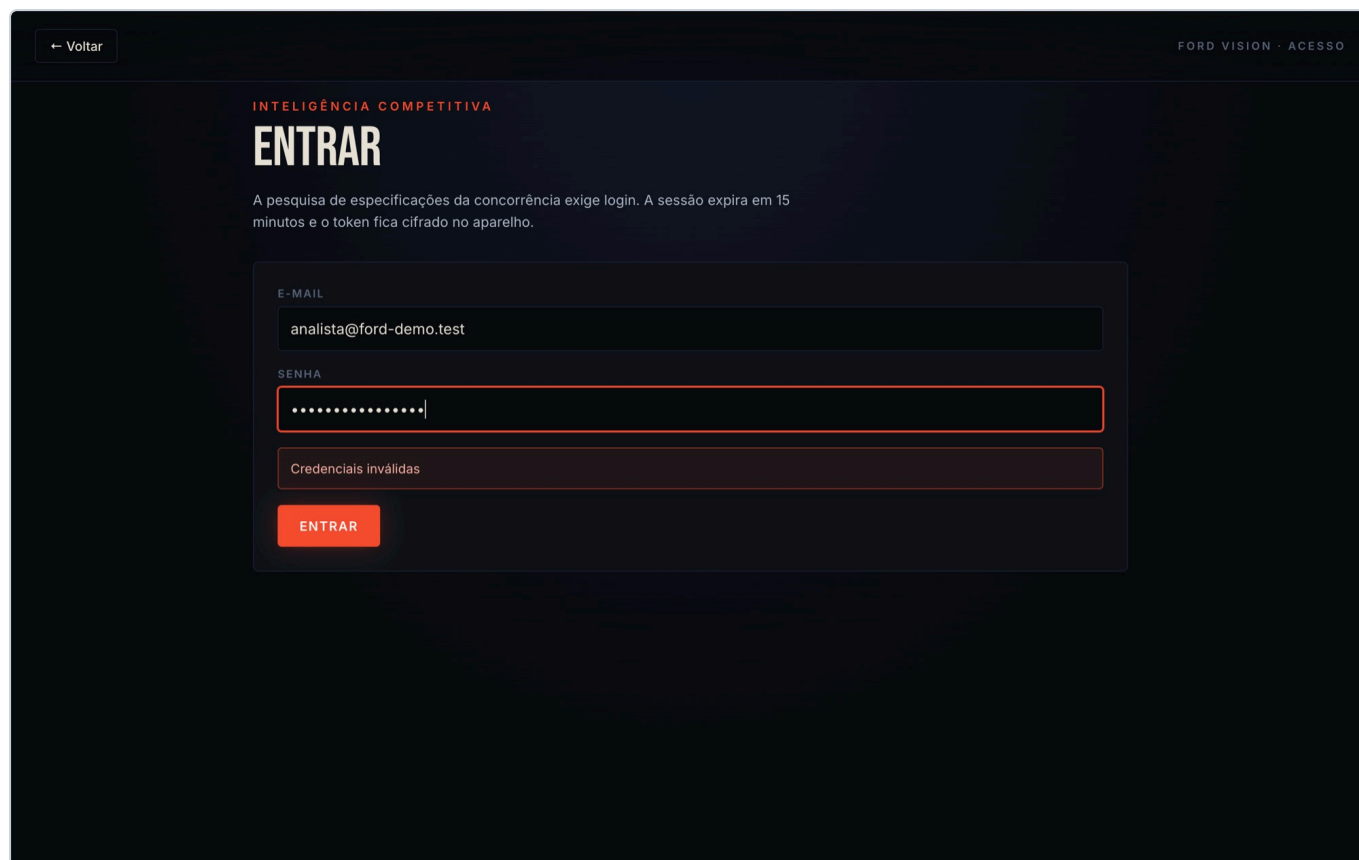


Figura 8 — Login com credencial inválida: mensagem genérica (sem revelar se a conta existe); validação também no cliente.

Testes automatizados de segurança da API (npm test)

- ✓ login válido devolve JWT HS256 com expiração de 15 min
 - ✓ senha errada e usuário inexistente têm a mesma resposta
 - ✓ conta bloqueia após 5 falhas seguidas
 - ✓ rate limit do login devolve 429
 - ✓ token com alg none, assinado com outro segredo ou expirado é recusado
 - ✓ logout revoga o token antes da expiração
 - ✓ boot falha com JWT_SECRET curto
 - ✓ JWT_SECRET_FILE (secret montado como arquivo) tem prioridade sobre a variável
 - ✓ headers de segurança do Helmet e sem X-Powered-By
 - ✓ CORS só libera origens da allowlist
 - ✓ JSON malformado vira 400 sem stack trace
 - ✓ telemetria do app aceita só eventos da lista fechada
 - ✓ X-Request-Id é devolvido para correlacionar logs
 - ✓ sem token a API responde 401
 - ✓ matriz de permissões por perfil
 - ✓ Ranger Raptor: todas as especificações do slide vêm disponíveis
 - ✓ atributo inexistente fica explícito como NAO_DISPONIVEL, sem mudar o formato
 - ✓ veículo desconhecido devolve o mesmo formato com tudo NAO_DISPONIVEL
 - ✓ validação de entrada rejeita payload malformado ou malicioso
 - ✓ payload acima de 16kb é recusado com 413
- ```
i tests 20
i pass 20
i fail 0
```

**Rate limit** ( `express-rate-limit`, `server/src/app.js` ) com três limitadores:

| Limitador | Janela | Limite     | Uso                  |
|-----------|--------|------------|----------------------|
| api       | 15 min | 300 req/IP | Toda /api            |
| login     | 15 min | 10 req/IP  | POST /api/auth/login |
| telemetry | 15 min | 60 req/IP  | Eventos do app       |

Além disso há **lockout por conta**: 5 falhas seguidas bloqueiam a conta por 15 min ( 423 ), o que pega brute force distribuído que o limite por IP não pega. O login responde igual para “usuário não existe” e “senha errada”, com hash *dummy* para igualar o tempo, e assim não revela quais contas existem.

**JWT seguro** ( server/src/auth/tokens.js ):

```
jwt.sign({ sub: user.id, role: user.role, name: user.name }, config.JWT_SECRET,
 { algorithm: 'HS256', expiresIn: '15m', issuer, audience, jwtid: randomUUID() })

jwt.verify(token, config.JWT_SECRET, { algorithms: ['HS256'], issuer, audience })
```

- segredo só por ambiente ( JWT\_SECRET ) ou arquivo montado ( JWT\_SECRET\_FILE , preferido em Docker/K8s). O boot **falha** se o segredo tiver menos de 32 caracteres ( server/src/config.js );
- lista fixa de algoritmos: token alg: none ou assinado com outro segredo é recusado (testado);
- jti + **denylist**: POST /api/auth/logout revoga o token antes de expirar, e a contenção de incidente usa o mesmo mecanismo;
- regras Semgrep próprias: ford-hardcoded-jwt-secret e ford-jwt-verify-without-algorithms .

**Headers e CORS**: Helmet com CSP default-src 'none' (a API só serve JSON), HSTS, nosniff e X-Powered-By removido. O CORS aceita só origens da allowlist CORS\_ORIGINS ( https://localhost e capacitor://localhost do app, mais a URL de dev). /metrics fica em **outra porta (9464)**, fora da rede pública.

#### Mobile:

- **CSP** no index.html gerada no build ( vite.config.js ): script-src 'self' 'wasm-unsafe-eval' (só o decoder WASM do three.js), connect-src restrito à API, object-src 'none' . Verificado no navegador: o modelo 3D carrega sem violação;
- src/services/api.js recusa URL http:// que não seja host local de desenvolvimento. No APK a requisição sai pelo **CapacitorHttp nativo**, com timeout de 10 s;
- o CSV exportado neutraliza **formula injection** ( = , + , - , @ ganham ' ) e escapa aspas ( src/services/csv.js ). A correção também foi aplicada ao relatório já existente ( ReportPage.jsx ), que antes juntava as células com vírgula pura.

## 2.3 Controle de acesso por perfil (RBAC)

A rubrica cita Brigadista, Gestor e Administrador. Adaptamos ao domínio do projeto mantendo os três níveis:

| Perfil no app        | Equivalente na rubrica | Pode                                                                                 |
|----------------------|------------------------|--------------------------------------------------------------------------------------|
| VIEWER<br>(Consulta) | Brigadista (operação)  | Login, listar veículos, pesquisar especificações                                     |
| ANALISTA             | Gestor                 | Tudo do VIEWER + <b>manter specs de concorrentes</b> ( PUT /api/vehicles/:id/specs ) |

| Perfil no app | Equivalente na rubrica | Pode                                                                  |
|---------------|------------------------|-----------------------------------------------------------------------|
| ADMIN         | Administrador          | Tudo + <b>criar/remover veículos, listar usuários e ver auditoria</b> |

```
router.put('/vehicles/:id/specs', authorize(ROLES.ANALISTA, ROLES.ADMIN), validateBody(upsertSchema), handler)
router.post('/vehicles', authorize(ROLES.ADMIN), validateBody(createSchema), handler)
router.delete('/vehicles/:id', authorize(ROLES.ADMIN), handler)
router.use(authorize(ROLES.ADMIN)) // /api/admin/*
```

A decisão é **sempre no servidor**. O app só esconde o painel de auditoria para quem não é ADMIN, e isso é UX, não segurança. O teste `server/test/rbac.test.js` percorre a matriz inteira. **Verificado com a API rodando:** o ANALISTA consegue PUT (200), leva 403 no DELETE, e o ADMIN vê o evento `VEHICLE_SPECS_UPSERT` com `userId` e `role` do analista.

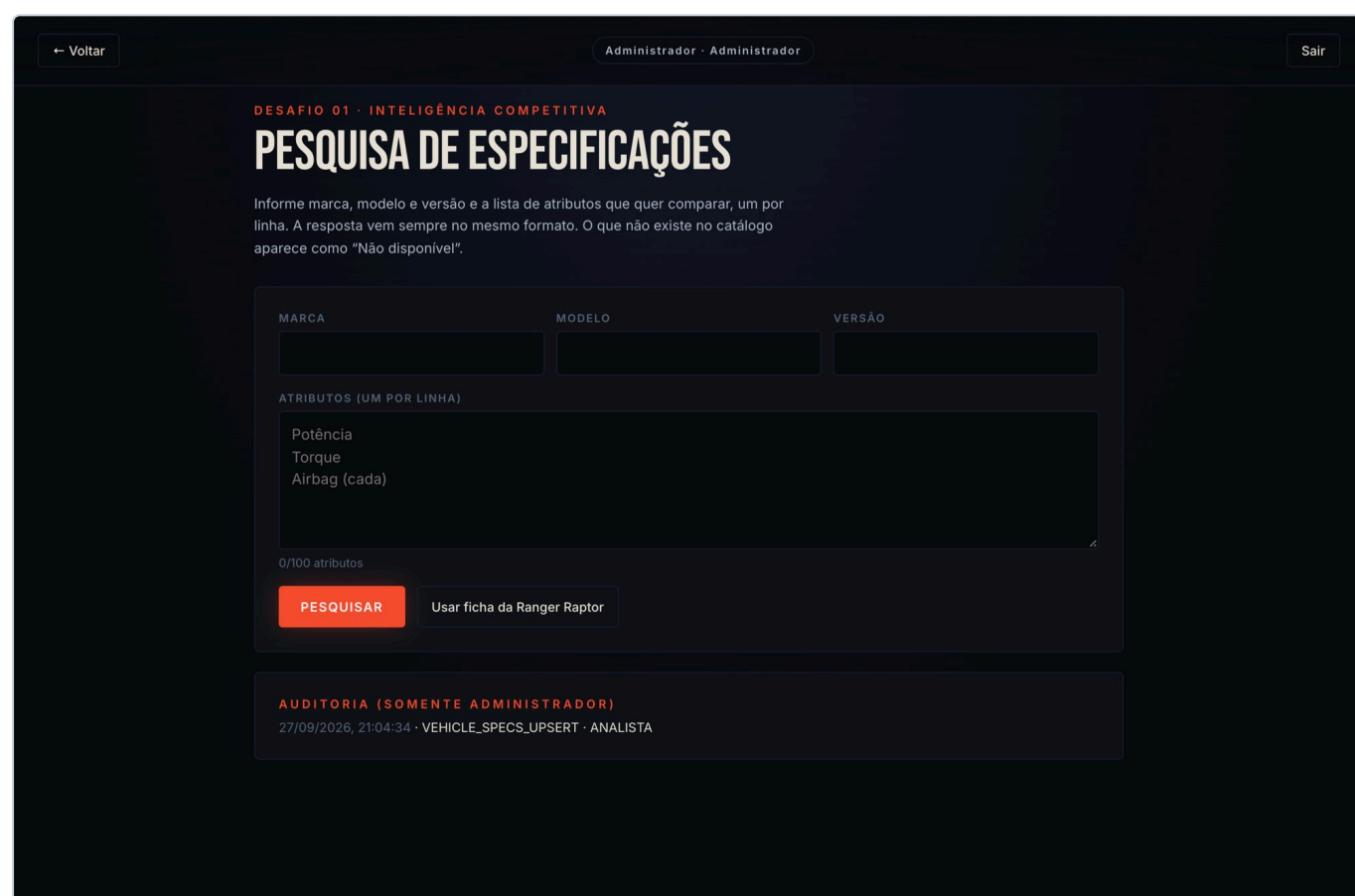


Figura 9 — Perfil ADMIN: painel de auditoria mostra a alteração feita pelo ANALISTA (VEHICLE\_SPECS\_UPSERT). A tentativa de DELETE do analista recebeu 403 e não aparece como alteração.

## 2.4 Segurança MQTT/TLS para IoT — não aplicável

O projeto **não tem dispositivo IoT, broker MQTT nem telemetria veicular**: é um app de vitrine e comparação de especificações. Colocar um broker só para cumprir o item aumentaria a superfície de ataque sem função no produto. Se um dia houver integração com veículo conectado, o requisito fica definido:

- MQTT **só sobre TLS 1.2+ (porta 8883)**, porta 1883 fechada;
- autenticação **por dispositivo** (certificado cliente/mTLS ou usuário próprio), nunca credencial compartilhada;

- ACL por tópico ( `veiculo/{id}/telemetria` só publica o próprio `id` );
- nada de localização precisa sem base legal (ver LGPD, 4.3).

A mesma lógica de transporte já vale para o app: o release **só aceita HTTPS** (ver 2.5).

## 2.5 Hardening do Android

| Controle                                                                                         | Arquivo                                                                   | Efeito                                                                           |
|--------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|----------------------------------------------------------------------------------|
| <code>cleartextTrafficPermitted="false"</code> + só CAs do sistema                               | <code>android/app/src/main/res/xml/network_security_config.xml</code>     | Release só fala HTTPS, e CA instalada pelo usuário (proxy MITM) não é confiada   |
| HTTP liberado <b>só no debug</b> e só para <code>10.0.2.2 / localhost</code>                     | <code>android/app/src/debug/res/xml/network_security_config.xml</code>    | Permite testar com a API local sem enfraquecer o release                         |
| <code>allowBackup="false"</code> + <code>dataExtractionRules</code>                              | <code>AndroidManifest.xml</code> , <code>data_extraction_rules.xml</code> | Dados do app não vão para backup em nuvem nem para transferência entre aparelhos |
| R8 ( <code>minifyEnabled</code> , <code>shrinkResources</code> , <code>debuggable false</code> ) | <code>android/app/build.gradle</code>                                     | Release sem código morto, ofuscado e não depurável                               |
| <code>allowMixedContent: false</code>                                                            | <code>capacitor.config.json</code>                                        | WebView não carrega HTTP dentro de página HTTPS                                  |

## 2.6 IaC Security

**Dockerfile** ( `server/Dockerfile` ):

```
FROM node:22-alpine@sha256:0a7108bf...402 AS deps # imagem fixada por digest
RUN npm ci --omit=dev --ignore-scripts # sem devDeps, sem scripts de instalação
FROM node:22-alpine@sha256:0a7108bf...402 AS runtime
RUN apk upgrade --no-cache \
 && addgroup -S -g 10001 app && adduser -S -D -H -u 10001 -G app app \
 && rm -rf /usr/local/lib/node_modules/npm /usr/local/bin/npm /usr/local/bin/npx /opt/yarn*
COPY --chown=root:root src ./src # código é só leitura para o processo
USER 10001:10001
HEALTHCHECK CMD ["node", "-e", "fetch('http://127.0.0.1:3000/healthz')..."]
```

**docker-compose** ( `infra/docker-compose.yml` ): `read_only: true`, `cap_drop: [ALL]`, `no-new-privileges`, `tmpfs` só em `/tmp`, limite de CPU e memória, portas publicadas só em `127.0.0.1`, e `users.json` entregue como `secret`.

**Kubernetes** ( `infra/k8s/api.yaml` ): namespace com Pod Security `restricted`, `runAsNonRoot` com UID `10001`, `readOnlyRootFilesystem`, `allowPrivilegeEscalation: false`, `capabilities.drop: [ALL]`, `seccompProfile: RuntimeDefault`, segredos **como arquivo** ( `JWT_SECRET_FILE` ), `automountServiceAccountToken: false`, `requests/limits`, `probes` e **NetworkPolicy** (só o ingress acessa a `3000`, só o Prometheus acessa a `9464`, sem egress).

Resultado do Checkov nesses arquivos: **0 falhas** (1 exceção documentada: digest da imagem, que só existe depois do build).

**Checkov (local) — Dockerfile, Kubernetes e GitHub Actions**

```
kubernetes scan results:
Passed checks: 91, Failed checks: 0, Skipped checks: 1
dockerfile scan results:
Passed checks: 65, Failed checks: 0, Skipped checks: 0
github_actions scan results:
Passed checks: 188, Failed checks: 0, Skipped checks: 0
```

## 3. Atividade 3 — Observabilidade, Monitoramento e Resposta (peso 2,0)

### 3.1 Logs estruturados

A API usa **pino**: uma linha JSON por evento, com `timestamp` ISO, `level`, `event`, `req.id` (correlação, devolvido no header `X-Request-Id`), `userId` e `role`. Exemplos **reais** gerados pela API ( `evidencias/exemplo-logs.jsonl` ):

```
{
 "level": "INFO",
 "timestamp": "2026-09-27T23:33:24.803Z",
 "service": "ford-specs-api",
 "req": {
 "id": "fa7b1cf0-...",
 "method": "POST",
 "url": "/api/auth/login",
 "ip": "loopback",
 "event": "LOGIN_SUCCESS",
 "userId": "218205b9-...",
 "role": "ANALISTA",
 "message": "login ok"
 }
}
{
 "level": "WARN",
 "timestamp": "2026-09-27T23:33:25.014Z",
 "service": "ford-specs-api",
 "req": {
 "id": "7cc6a18b-...",
 "method": "POST",
 "url": "/api/auth/login",
 "ip": "loopback",
 "event": "LOGIN_FAILURE",
 "locked": false,
 "message": "falha de login"
 }
}
{
 "level": "WARN",
 "timestamp": "2026-09-27T23:33:24.811Z",
 "service": "ford-specs-api",
 "req": {
 "id": "42907bb6-...",
 "method": "POST",
 "url": "/api/vehicles",
 "userId": "218205b9-...",
 "role": "ANALISTA",
 "event": "AUTHZ_DENIED",
 "route": "/api/vehicles",
 "required": ["ADMIN"],
 "message": "acesso negado por perfil"
 }
}
{
 "level": "INFO",
 "timestamp": "2026-09-27T23:33:49.939Z",
 "service": "ford-specs-api",
 "event": "AUDIT",
 "action": "VEHICLE_SPECS_UPSERT",
 "userId": "218205b9-...",
 "role": "ANALISTA",
 "details": {
 "vehicle": "toyota-hilux-gr-s",
 "atributos": ["Airbag (cada)"]
 },
 "message": "auditoria: VEHICLE_SPECS_UPSERT"
}
```

| Evento                                                                                   | Quando                                                     |
|------------------------------------------------------------------------------------------|------------------------------------------------------------|
| LOGIN_SUCCESS / LOGIN_FAILURE / LOGIN_BLOCKED / LOGOUT                                   | Autenticação                                               |
| AUTH_INVALID_TOKEN / AUTHZ_DENIED                                                        | JWT inválido/expirado/revogado; perfil sem permissão       |
| RATE_LIMITED / VALIDATION_FAILED                                                         | Abuso e payload rejeitado                                  |
| AUDIT ( VEHICLE_SPECS_UPSERT , VEHICLE_CREATE , VEHICLE_DELETE )                         | <b>Alterações críticas</b> , com quem, perfil e o quê      |
| SPEC_SEARCH                                                                              | Uso do Desafio 01 (veículo, atributos pedidos e faltantes) |
| MOBILE_APP_START / MOBILE_MODEL_LOAD_FAILURE / MOBILE_API_ERROR / MOBILE_SESSION_EXPIRED | Telemetria do app                                          |
| UNHANDLED_ERROR / SERVER_START / SERVER_STOP                                             | Operação                                                   |

## Logs estruturados reais gerados pela API (1 linha JSON por evento)

```
{
 "level": "INFO",
 "timestamp": "2026-09-27T23:33:24.803Z",
 "service": "ford-specs-api",
 "req": {
 "id": "fa7b1cf0-1098-47d0-a844-12db84d1822f",
 "method": "POST",
 "url": "/api/auth/login",
 "ip": "loopback",
 "event": "LOGIN_SUCCESS",
 "userId": "218205b9-48db-49c1-8b82-1acf87e01ab2",
 "role": "ANALISTA",
 "message": "login ok"
 }
}
{"level": "INFO",
 "timestamp": "2026-09-27T23:33:24.808Z",
 "service": "ford-specs-api",
 "req": {
 "id": "255e0c0e-ba69-4dd7-9c2d-2ebdfdc3b263",
 "method": "POST",
 "url": "/api/specs/search",
 "ip": "loopback",
 "userId": "218205b9-48db-49c1-8b82-1acf87e01ab2",
 "role": "ANALISTA",
 "event": "SPEC_SEARCH",
 "vehicle": "ford-ranger-raptor-3-0-v6",
 "requested": 6,
 "missing": 1,
 "message": "pesquisa de especificações"
 }
}
{"level": "INFO",
 "timestamp": "2026-09-27T23:33:24.810Z",
 "service": "ford-specs-api",
 "req": {
 "id": "dbfd8f31-9ab5-454f-9f13-118cc1a9550c",
 "method": "POST",
 "url": "/api/specs/search",
 "ip": "loopback",
 "userId": "218205b9-48db-49c1-8b82-1acf87e01ab2",
 "role": "ANALISTA",
 "event": "VALIDATION_FAILED",
 "route": "/api/specs/search",
 "issues": 4,
 "message": "payload rejeitado"
 }
}
{"level": "WARN",
 "timestamp": "2026-09-27T23:33:24.811Z",
 "service": "ford-specs-api",
 "req": {
 "id": "42907bb6-7e61-4c09-b702-1b5948b92472",
 "method": "POST",
 "url": "/api/vehicles",
 "ip": "loopback",
 "userId": "218205b9-48db-49c1-8b82-1acf87e01ab2",
 "role": "ANALISTA",
 "event": "AUTHZ_DENIED",
 "route": "/api/vehicles",
 "required": ["ADMIN"],
 "message": "acesso negado por perfil"
 }
}
{"level": "WARN",
 "timestamp": "2026-09-27T23:33:25.014Z",
 "service": "ford-specs-api",
 "req": {
 "id": "7cc6a18b-ec85-4be8-9dc3-5bd8ac1383b4",
 "method": "POST",
 "url": "/api/auth/login",
 "ip": "loopback",
 "event": "LOGIN_FAILURE",
 "locked": false,
 "message": "falha de login"
 }
}
{"level": "INFO",
 "timestamp": "2026-09-27T23:33:25.015Z",
 "service": "ford-specs-api",
 "req": {
 "id": "a2e09763-bc9d-4f72-a942-2d0e3d5254ca",
 "method": "POST",
 "url": "/api/telemetry/events",
 "ip": "loopback",
 "event": "MOBILE_APP_START",
 "platform": "android",
 "appVersion": "1.0.0",
 "message": "evento do app"
 }
}
{"level": "ERROR",
 "timestamp": "2026-09-27T23:33:25.016Z",
 "service": "ford-specs-api",
 "req": {
 "id": "a6c579ba-4f87-471d-8226-48c61b9e93d6",
 "method": "POST",
 "url": "/api/telemetry/events",
 "ip": "loopback",
 "event": "MOBILE_MODEL_LOAD_FAILURE",
 "platform": "android",
 "screen": "home",
 "message": "evento do app"
 }
}
{"level": "WARN",
 "timestamp": "2026-09-27T23:33:26.434Z",
 "service": "ford-specs-api",
 "req": {
 "id": "1b36e329-fd38-4230-8a2c-891a03f2c2eb",
 "method": "POST",
 "url": "/api/auth/login",
 "ip": "loopback",
 "event": "RATE_LIMITED",
 "limiter": "login",
 "message": "rate limit atingido"
 }
}
{"level": "INFO",
 "timestamp": "2026-09-27T23:33:34.716Z",
 "service": "ford-specs-api",
 "event": "SERVER_STOP",
 "signal": "SIGTERM",
 "message": "encerrando"
}
```

**O que nunca vai para o log** (redaction do pino em `server/src/logger.js`): `password`, `header Authorization` (JWT), `cookies` e `tokens`. O IP é  **mascarado**  ( `189.10.20.xxx` ) por LGPD. Verificação feita no log real: **0** ocorrências de `password` ou `eyJ`. O `X-Request-Id` recebido só é aceito se for um UUID válido, o que evita *log forging*.

## 3.2 Métricas e alertas

A API expõe métricas Prometheus em `:9464/metrics`. As regras ficam em `infra/prometheus/alerts.yml`:

| Métrica                                                  | Alerta                           | Condição                | Severidade | Ação                                        |
|----------------------------------------------------------|----------------------------------|-------------------------|------------|---------------------------------------------|
| <code>auth_login_total{result}</code>                    | BruteForceSuspeito               | > 20 falhas em 5 min    | critical   | Playbook 1                                  |
| <code>rate_limit_hits_total{limiter}</code>              | RateLimitDisparado               | > 10 bloqueios em 5 min | warning    | Verificar origem, avaliar bloqueio no WAF   |
| <code>authz_denied_total{reason="forbidden_role"}</code> | TentativaDeEscalaçãoDePrivilegio | > 10 em 10 min          | critical   | Playbook 2                                  |
| <code>authz_denied_total{reason="invalid_token"}</code>  | TokensInvalidosEm Massa          | > 30 em 10 min          | warning    | Suspeita de token forjado; conferir segredo |

| Métrica                                        | Alerta                                 | Condição               | Severidade | Ação                                       |
|------------------------------------------------|----------------------------------------|------------------------|------------|--------------------------------------------|
| <code>admin_changes_total{action}</code>       | <code>AlteracaoAdministrativa</code>   | qualquer               | info       | Conferir na trilha de auditoria            |
| <code>up</code>                                | <code>ApiFora</code>                   | 0 por 1 min            | critical   | Restart, verificar logs                    |
| <code>http_requests_total{status}</code>       | <code>TaxaDeErro5xxAlta</code>         | > 5% por 5 min         | critical   | Logs <code>level=ERROR</code>              |
| <code>http_request_duration_seconds</code>     | <code>LatenciaP95Alta</code>           | p95 > 500 ms por 5 min | warning    | Recursos/dependências                      |
| <code>process_cpu_seconds_total</code>         | <code>CpuAlta</code>                   | > 80% por 5 min        | warning    | Sobrecarga ou abuso                        |
| <code>mobile_client_events_total{event}</code> | <code>FalhaCarregamentoModelo3D</code> | > 5 em 15 min          | warning    | Conferir <code>.glb</code> e versão do app |

**Mobile:** o app reporta eventos por uma **lista fechada** (`APP_START`, `MODEL_LOAD_FAILURE`, `API_ERROR`, `SESSION_EXPIRED`), sem texto livre, sem dado pessoal e sem localização. Campo extra, como `latitude`, é rejeitado (testado). O `ModelErrorBoundary` captura falha do modelo 3D, mostra a mensagem de erro em vez da tela em branco e reporta o evento.

**ML:** o projeto não tem modelo de ML em produção. O equivalente monitorado é a qualidade da resposta do Desafio 01: `spec_search_total{found}` e `spec_attributes_missing_total` (taxa de "não disponível"). Uma alta nesses números indica catálogo desatualizado.

### 3.3 Dashboards

A rubrica aceita "Grafana, Kibana, Azure Monitor ou equivalente". O projeto tem os dois:

**a) Painel de segurança embutido na API (usado nos prints):** `http://127.0.0.1:9464/dashboard/`. Roda junto com a API, sem Docker, e lê ao vivo as mesmas métricas Prometheus (`/metrics`) e os eventos de segurança dos logs estruturados. Ele avalia **as mesmas 9 regras** de `infra/prometheus/alerts.yml` numa janela deslizante (equivalente ao `increase()` do PromQL). Fica numa porta **interna**, que por padrão só escuta em `127.0.0.1`. Código em `server/src/dashboard/`.

- **Visão geral:** requisições/min, taxa de erro 5xx, logins falhos (5 min), latência p95, CPU e memória;
- **Alertas:** estado de cada regra (OK / disparado), com ícone e rótulo de severidade;
- **Eventos de segurança:** logins por resultado; 401/403, rate limit e payload inválido; requisições por classe de status;
- **Mobile e Desafio 01:** eventos do app, pesquisas e atributos não disponíveis;
- **Logs:** tabela dos últimos eventos (`LOGIN_FAILURE`, `AUTHZ_DENIED`, `RATE_LIMITED`, `AUDIT`, ...), com IP mascarado e request ID.

**b) Grafana (produção):** o dashboard "**Ford Specs API - Security Monitoring**" é provisionado automaticamente (`infra/grafana/dashboards/ford-security.json`, 18 painéis), com Prometheus (métricas e alertas) e Loki/Alloy (logs). Para subir: `cd infra && cp .env.example .env && docker compose up -d --build`.

Para gerar tráfego nos dois: `npm --prefix server run simulate`.

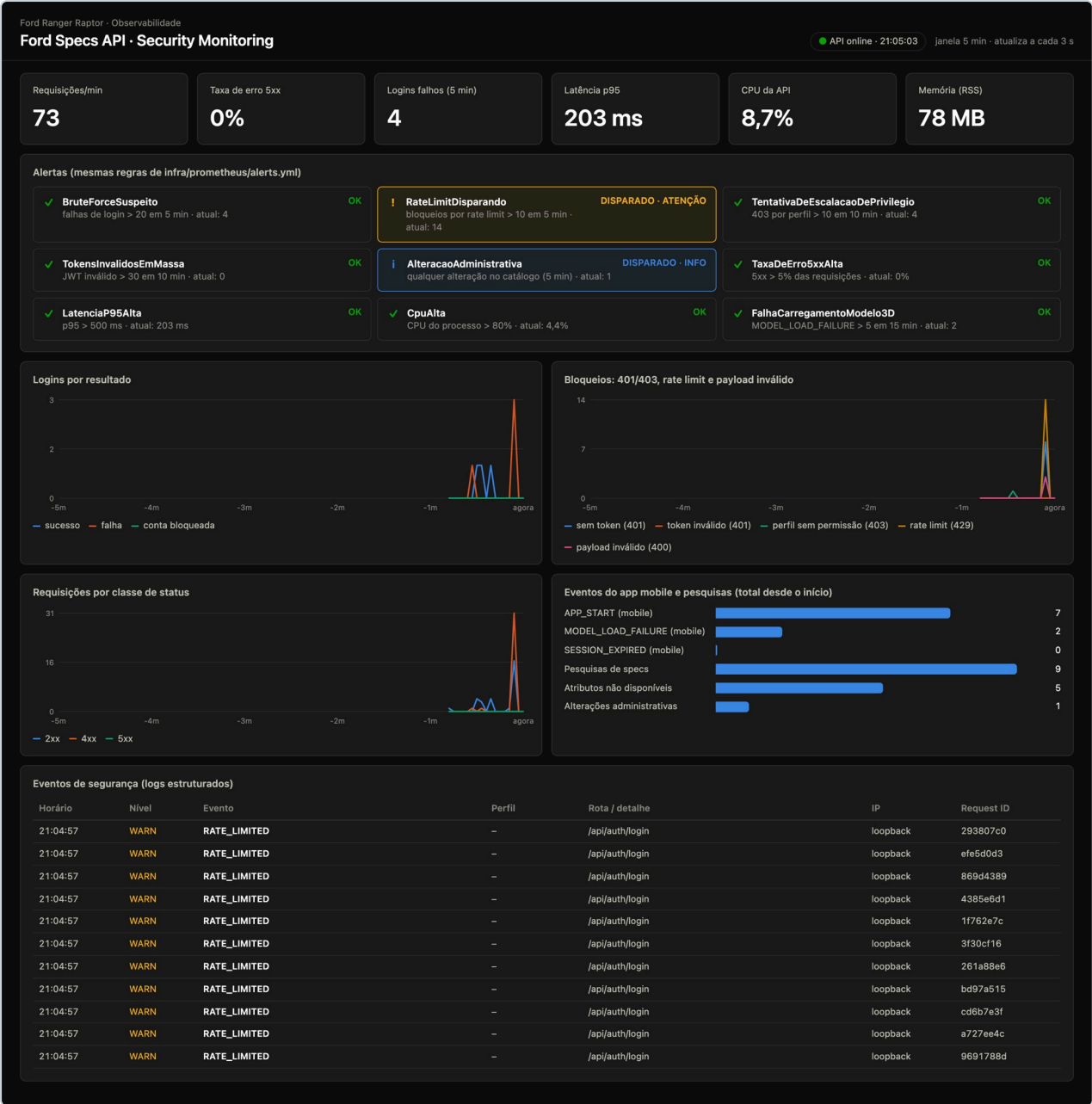
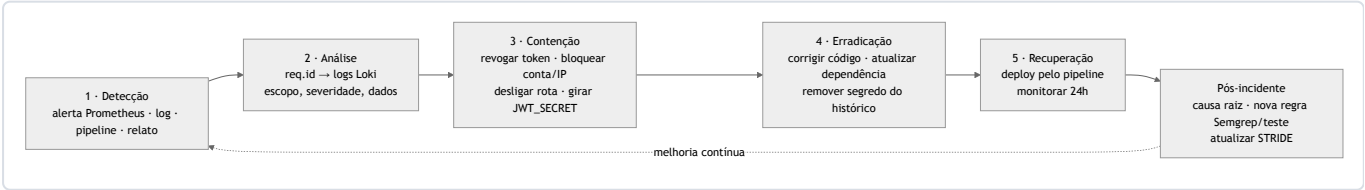


Figura 10 — Painel de monitoramento de segurança com dados reais após tráfego simulado (brute force, 403, payload inválido, eventos do app). O alerta RateLimitDisparando disparou e AlteracaoAdministrativa registrou a mudança auditada.

3.4 Plano de resposta a incidentes

Detalhado em `RESPOSTA_A_INCIDENTES.md` . Resumo do fluxo:



| Severidade   | Exemplo                                                            | Tempo de resposta   |
|--------------|--------------------------------------------------------------------|---------------------|
| SEV1 crítica | Segredo JWT vazado, dados expostos, API fora                       | Imediato (≤ 15 min) |
| SEV2 alta    | Brute force ativo, tentativa de escalação, CVE crítica em produção | ≤ 1 h               |

| Severidade        | Exemplo                                  | Tempo de resposta |
|-------------------|------------------------------------------|-------------------|
| <b>SEV3</b> média | Rate limit disparando, falha 3D em massa | ≤ 1 dia útil      |

## 4. Atividade 4 — Compliance, Riscos e Segurança Contínua (peso 2,5)

### 4.1 Revisão final de riscos (STRIDE + DevSecOps)

| #   | STRIDE                 | Ameaça no projeto                                                  | Controle implementado                                                                                                                         | Onde                                                  | Risco residual                         |
|-----|------------------------|--------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------|----------------------------------------|
| R1  | Spoofing               | Login com credencial de outro usuário / brute force                | bcrypt 12, rate limit 10/15 min, lockout 5 falhas, resposta indistinguível, alerta <code>BruteForceSuspeito</code>                            | <code>routes/auth.js</code> , <code>lockout.js</code> | Baixo                                  |
| R2  | Spoofing               | Token forjado ( <code>alg:none</code> , outro segredo)             | <code>algorithms: ['HS256']</code> , issuer/audience, segredo ≥ 32 chars                                                                      | <code>tokens.js</code> , <code>config.js</code>       | Baixo                                  |
| R3  | Tampering              | Alteração indevida do catálogo                                     | RBAC server-side + zod <code>strictObject</code> + auditoria                                                                                  | <code>routes/specs.js</code>                          | Baixo                                  |
| R4  | Tampering              | Token adulterado no aparelho                                       | AES-GCM (autenticado): adulteração é detectada e descartada                                                                                   | <code>secureStore.js</code>                           | Baixo                                  |
| R5  | Repudiation            | Analista nega ter alterado dados                                   | Evento <code>AUDIT</code> com <code>userId</code> , role, <code>requestId</code> e diff de atributos; consulta só ADMIN; logs retidos 30 dias | <code>audit.js</code> , Loki                          | Baixo                                  |
| R6  | Information disclosure | Segredo no repositório                                             | <code>.gitignore</code> , <code>.env.example</code> vazio, Gitleaks no histórico, regra Semgrep                                               | pipeline                                              | Baixo                                  |
| R7  | Information disclosure | Interceptação (MITM) no celular                                    | HTTPS obrigatório no release, sem CA de usuário, sem cleartext                                                                                | <code>network_security_config.xml</code>              | Baixo                                  |
| R8  | Information disclosure | Token lido do storage/backup                                       | Criptografia local + <code>allowBackup=false</code> + regras de extração                                                                      | <code>secureStore.js</code> , manifest                | Médio (aparelho com root)              |
| R9  | Information disclosure | Stack trace ou dado pessoal em log/resposta                        | Handler de erro genérico, redaction, IP mascarado                                                                                             | <code>app.js</code> , <code>logger.js</code>          | Baixo                                  |
| R10 | Denial of service      | Flood de requisições / payload gigante                             | Rate limit, body ≤ 16 kB, <code>max(100)</code> atributos, limites de CPU/mem no container                                                    | <code>app.js</code> , compose, k8s                    | Médio (DDoS volumétrico exige WAF/CDN) |
| R11 | Elevation of privilege | VIEWER chamando rota de ADMIN / enviando <code>role</code> no body | <code>authorize()</code> por rota, schema rejeita campo extra, alerta de escalação                                                            | <code>middleware/auth.js</code>                       | Baixo                                  |
| R12 | Elevation of privilege | Fuga do container                                                  | Não-root (10001), read-only, <code>cap_drop ALL</code> , <code>seccomp, no-new-privileges</code>                                              | Dockerfile, compose, k8s                              | Baixo                                  |
| D1  | DevSecOps              | Dependência vulnerável                                             | npm audit gate + Dependabot semanal + execução agendada                                                                                       | pipeline                                              | Baixo                                  |
| D2  | DevSecOps              | Supply chain do CI (action comprometida)                           | Actions fixadas por SHA, <code>permissions: read</code> , cooldown 7 dias                                                                     | workflow                                              | Baixo                                  |

| #  | STRIDE    | Ameaça no projeto                | Controle implementado               | Onde     | Risco residual |
|----|-----------|----------------------------------|-------------------------------------|----------|----------------|
| D3 | DevSecOps | Código inseguro chegando ao main | Semgrep + 20 testes como gate de PR | pipeline | Baixo          |

### Riscos aceitos:

| ID   | Risco                                                                                                         | Justificativa                                                                                                                                                                             | Revisão                |
|------|---------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------|
| AR-1 | 3 vulnerabilidades <b>moderadas</b> em <code>uuid</code> via <code>@capacitor/cli</code> → <code>xcode</code> | Dependência só de desenvolvimento e só usada para projetos iOS (não geramos iOS); não entra no APK. O <code>--force</code> rebaixaria a CLI do Capacitor (quebra). O Dependabot acompanha | Semanal                |
| AR-2 | Catálogo, denylist de tokens e logout ficam em memória                                                        | Escopo acadêmico com instância única; em produção, Redis para denylist/checkout e banco para catálogo                                                                                     | Antes de ir a produção |
| AR-3 | Scores do relatório são mockados                                                                              | Já sinalizado no app ("Dados mockados para demonstração")                                                                                                                                 | —                      |

## 4.2 Mapeamento com normas e boas práticas

### OWASP ASVS 5.0 (nível 1, com itens de nível 2):

| Capítulo ASVS                  | Como atendemos                                                                                                          |
|--------------------------------|-------------------------------------------------------------------------------------------------------------------------|
| V1 Encoding & Sanitization     | Saída React como texto (sem <code>dangerouslySetInnerHTML</code> , bloqueado no Semgrep); CSV com escape e anti-fórmula |
| V2 Validation & Business Logic | <code>zod strictObject</code> , limites de tamanho/quantidade, rejeição de duplicados                                   |
| V3 Web Frontend Security       | CSP no app, Helmet na API, <code>referrerPolicy: no-referrer</code> , <code>credentials: omit</code>                    |
| V4 API & Web Service           | CORS por allowlist, <code>Content-Type JSON</code> , 413 para payload grande, erros sem detalhe interno                 |
| V6 Authentication              | bcrypt 12, logout, rate limit, sem enumeração de usuário, senha mínima de 12 na criação                                 |
| V7 Session Management          | JWT 15 min, revogação por <code>jti</code> , logout invalida no servidor, expiração checada no app                      |
| V8 Authorization               | RBAC em toda rota, negação por padrão, decisão no servidor                                                              |
| V9 Self-contained Tokens       | Algoritmo fixo, <code>iss / aud / exp / jti</code> validados                                                            |
| V11 Cryptography               | AES-GCM 256 com IV aleatório, chave não extraível; bcrypt; <code>randomBytes</code> para segredos                       |
| V12 Secure Communication       | HTTPS obrigatório no release, HSTS                                                                                      |
| V13 Configuration              | Segredos fora do código, boot falha com config fraca, <code>/metrics</code> isolado                                     |
| V14 Data Protection            | Minimização (ver 4.3), backup desligado no Android                                                                      |
| V16 Security Logging           | Logs estruturados, eventos de segurança, redaction, correlação por <code>req.id</code>                                  |

### OWASP API Security Top 10 (2023):

| Item                       | Controle                                                                                                   |
|----------------------------|------------------------------------------------------------------------------------------------------------|
| API1 BOLA                  | IDs validados por regex; nenhum recurso pertence a usuário (catálogo compartilhado); escrita só por perfil |
| API2 Broken Authentication | JWT seguro, bcrypt, logout, rate limit de login                                                            |

| Item                                        | Controle                                                                                                                    |
|---------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|
| API3 Broken Object Property Level Auth.     | <code>strictObject</code> rejeita propriedades extras; resposta de usuário nunca inclui <code>passwordHash</code> (testado) |
| API4 Unrestricted Resource Consumption      | Rate limit, 16 kB, <code>max(100)</code> , limites de container                                                             |
| API5 Broken Function Level Auth.            | <code>authorize()</code> + regra Semgrep <code>ford-route-without-authorize</code>                                          |
| API6 Unrestricted Access to Sensitive Flows | Login com limite próprio e logout                                                                                           |
| API7 SSRF                                   | A API não faz requisição para URL vinda do cliente                                                                          |
| API8 Security Misconfiguration              | Helmet, CORS, erros genéricos, IaC verificado por Checkov/Trivy                                                             |
| API9 Improper Inventory                     | Rotas documentadas em <code>server/README.md</code> ; SBOM gerado no pipeline                                               |
| API10 Unsafe Consumption of APIs            | O app valida a resposta e trata erro; CSV neutraliza fórmula vinda da API                                                   |

OWASP Mobile Top 10 (2024):

| Item                                     | Controle                                                                                                    |
|------------------------------------------|-------------------------------------------------------------------------------------------------------------|
| M1 Improper Credential Usage             | Nenhuma credencial no APK; token só após login, cifrado                                                     |
| M2 Inadequate Supply Chain Security      | Dependabot (npm + Gradle), npm audit, actions por SHA                                                       |
| M3 Insecure Authentication/Authorization | Autorização sempre na API; sessão expira em 15 min                                                          |
| M4 Insufficient Input/Output Validation  | Validação no app + no servidor; CSP; CSV seguro                                                             |
| M5 Insecure Communication                | HTTPS obrigatório, sem cleartext no release, sem CA de usuário, CapacitorHttp nativo                        |
| M6 Inadequate Privacy Controls           | Telemetria com lista fechada, sem localização, IP mascarado                                                 |
| M7 Insufficient Binary Protections       | R8 (minify + shrink), <code>debuggable false</code> no release                                              |
| M8 Security Misconfiguration             | <code>allowBackup=false</code> , <code>allowMixedContent=false</code> , só a Activity de launcher exportada |
| M9 Insecure Data Storage                 | AES-GCM + chave não extraível; regra Semgrep contra token em texto puro                                     |
| M10 Insufficient Cryptography            | Algoritmos padrão (AES-GCM, bcrypt, HS256 com segredo ≥ 256 bits); nada de cripto caseira                   |

4.3 LGPD (dados pessoais, telemetria, localização)

| Dado                             | Coletado?          | Finalidade (art. 6º, I)              | Base legal (art. 7º)                      | Proteção                           | Retenção                                  |
|----------------------------------|--------------------|--------------------------------------|-------------------------------------------|------------------------------------|-------------------------------------------|
| Nome e e-mail do usuário interno | Sim                | Autenticação e auditoria             | Execução de contrato / legítimo interesse | bcrypt para senha; acesso só ADMIN | Enquanto o acesso existir; revisão mensal |
| Senha                            | Só o hash          | Autenticação                         | —                                         | bcrypt 12; nunca logada            | —                                         |
| IP                               | Mascarado nos logs | Segurança (rate limit, investigação) | Legítimo interesse (art. 7º, IX)          | Último octeto removido no log      | 30 dias (Loki)                            |

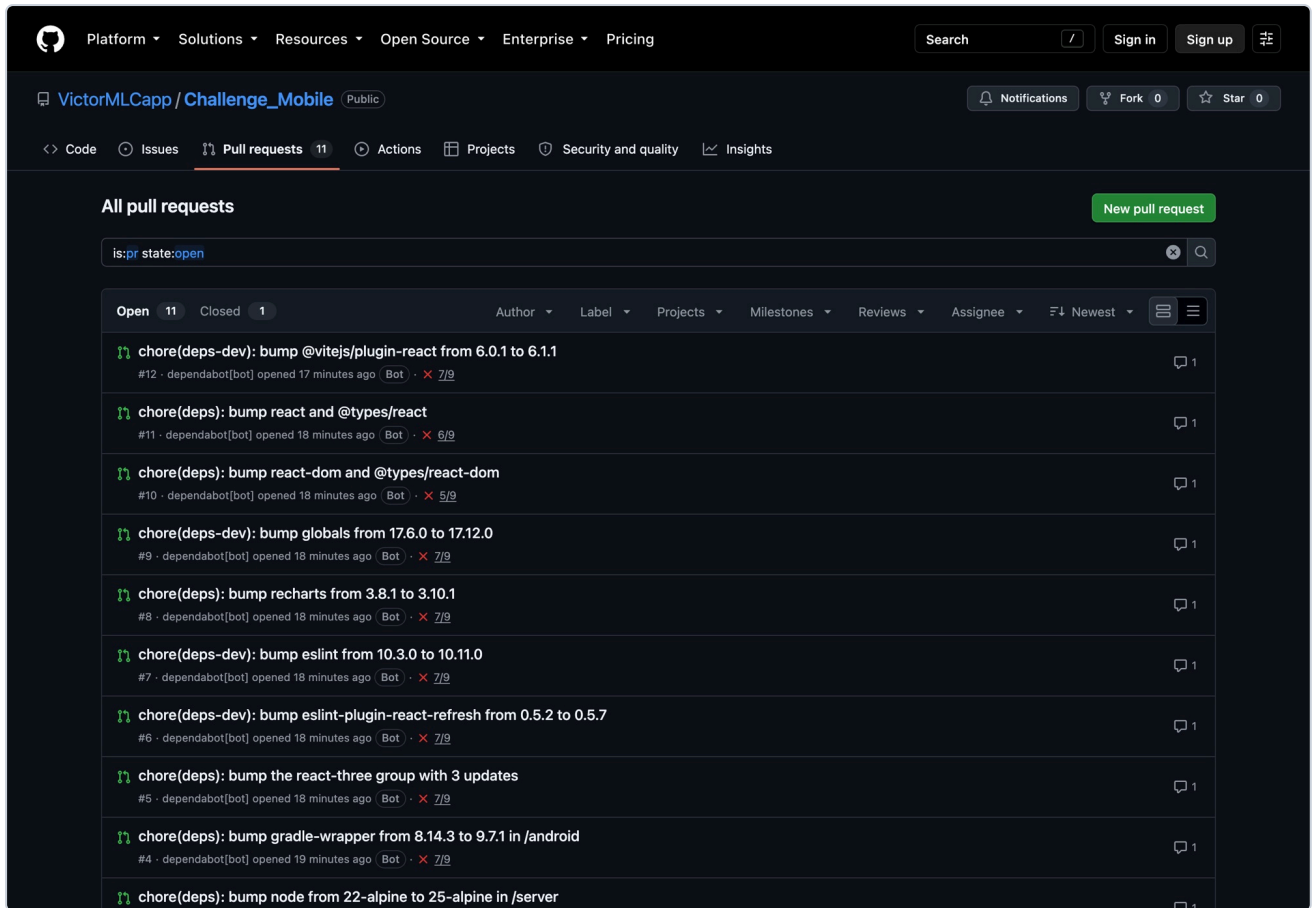
| Dado                                      | Coletado?                     | Finalidade (art. 6º, I)           | Base legal (art. 7º) | Proteção                                                | Retenção             |
|-------------------------------------------|-------------------------------|-----------------------------------|----------------------|---------------------------------------------------------|----------------------|
| Telemetria do app                         | Sim, <b>sem identificação</b> | Qualidade (falha 3D, erro de API) | Legítimo interesse   | Lista fechada de eventos; sem ID de aparelho            | 15 dias (Prometheus) |
| <b>Localização</b>                        | <b>Não</b>                    | Não há finalidade no produto      | —                    | Schema rejeita campos extras como <code>latitude</code> | —                    |
| CPF, documentos, contato de cliente final | <b>Não</b>                    | —                                 | —                    | —                                                       | —                    |

Princípios aplicados: **necessidade** (o mínimo para o serviço), **segurança** (em trânsito: HTTPS; em repouso: bcrypt e AES-GCM), **acesso restrito** (RBAC, auditoria só ADMIN), **retenção limitada** (Loki 30 dias com compactor, Prometheus 15 dias) e **transparência** (esta seção e o `SECURITY.md`). Pedidos de titular (art. 18) são atendidos por um ADMIN: o usuário é removido do `users.json`, e os logs expiram sozinhos.

## 4.4 Plano de segurança contínua

| Rotina                           | Frequência                    | Como                                                                                                                                                                | Responsável           | Evidência                                    |
|----------------------------------|-------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|----------------------------------------------|
| <b>Revisão de dependências</b>   | Semanal (segunda) + a cada PR | Dependabot (npm app/API, Gradle, Docker, Actions, cooldown 7 dias) e <code>npm audit</code> agendado no pipeline                                                    | Dev de plantão        | PRs do Dependabot; job SCA                   |
| <b>Testes de segurança</b>       | A cada PR / push              | Semgrep, Gitleaks, Trivy, Checkov, 20 testes da API                                                                                                                 | Pipeline (automático) | Artefatos SARIF/SBOM do Actions              |
| <b>Teste de segurança manual</b> | Por release                   | Checklist OWASP ASVS L1 + tentativa de <code>alg:none</code> , escalação, brute force ( <code>npm run simulate</code> )                                             | Time                  | Relatório no PR de release                   |
| <b>Auditoria de permissões</b>   | Mensal                        | <code>GET /api/admin/users</code> e <code>GET /api/admin/audit-events</code> : remover contas inativas, conferir quem é ADMIN/ANALISTA, girar senhas de serviço     | Administrador         | Registro da revisão (data, contas removidas) |
| <b>Rotação de segredos</b>       | Trimestral ou após incidente  | Novo <code>JWT_SECRET</code> (invalida todas as sessões); nova senha do Grafana                                                                                     | Administrador         | Registro de rotação                          |
| <b>Backup</b>                    | Diário (automático)           | <code>server/data/catalog.json</code> e <code>users.json</code> versionados/copiados; volumes <code>grafana-data</code> e <code>prometheus-data</code> com snapshot | Ops                   | Log do job de backup                         |
| <b>Teste de restauração</b>      | Mensal                        | Subir a stack num ambiente limpo a partir do backup e rodar <code>npm test</code> + uma pesquisa da Raptor                                                          | Ops                   | Registro do restore (tempo, resultado)       |
| <b>Revisão do STRIDE</b>         | A cada nova funcionalidade    | Atualizar a tabela 4.1 no PR                                                                                                                                        | Autor do PR           | Diff deste documento                         |

O backup e a restauração começaram na Fase 3. A fonte de verdade do catálogo é regenerável a partir da planilha ( `python3 server/scripts/build_catalog.py` ), e isso também serve de teste de restauração.



The screenshot shows the GitHub interface for the repository **VictorMLCapp / Challenge\_Mobile**. The top navigation bar includes links for Platform, Solutions, Resources, Open Source, Enterprise, and Pricing, along with a search bar and buttons for Sign in and Sign up. Below the repository name, there are buttons for Notifications, Fork (0), and Star (0). The main section is titled **All pull requests** and shows a list of 11 open pull requests, all created by **dependabot[bot]**. The pull requests are for updating dependencies, such as `@vitejs/plugin-react`, `react`, `react-dom`, `globals`, `recharts`, `eslint`, `eslint-plugin-react-refresh`, `the react-three group`, `gradle-wrapper`, and `node`. Each pull request has a title, a number, and a status (Open or Closed). The interface also includes a search bar with the filter `is:pr state:open` and a table of pull requests with columns for Open/Closed status, Author, Label, Projects, Milestones, Reviews, Assignee, and Newest.

| Open                                                                         | Closed | Author | Label | Projects | Milestones | Reviews | Assignee | Newest |
|------------------------------------------------------------------------------|--------|--------|-------|----------|------------|---------|----------|--------|
| 11                                                                           | 1      |        |       |          |            |         |          |        |
| <b>chore(deps-dev): bump @vitejs/plugin-react from 6.0.1 to 6.1.1</b>        |        |        |       |          |            |         |          |        |
| #12 · dependabot[bot] opened 17 minutes ago · Bot · 7/9                      |        |        |       |          |            |         |          |        |
| <b>chore(deps): bump react and @types/react</b>                              |        |        |       |          |            |         |          |        |
| #11 · dependabot[bot] opened 18 minutes ago · Bot · 6/9                      |        |        |       |          |            |         |          |        |
| <b>chore(deps): bump react-dom and @types/react-dom</b>                      |        |        |       |          |            |         |          |        |
| #10 · dependabot[bot] opened 18 minutes ago · Bot · 5/9                      |        |        |       |          |            |         |          |        |
| <b>chore(deps-dev): bump globals from 17.6.0 to 17.12.0</b>                  |        |        |       |          |            |         |          |        |
| #9 · dependabot[bot] opened 18 minutes ago · Bot · 7/9                       |        |        |       |          |            |         |          |        |
| <b>chore(deps): bump recharts from 3.8.1 to 3.10.1</b>                       |        |        |       |          |            |         |          |        |
| #8 · dependabot[bot] opened 18 minutes ago · Bot · 7/9                       |        |        |       |          |            |         |          |        |
| <b>chore(deps-dev): bump eslint from 10.3.0 to 10.11.0</b>                   |        |        |       |          |            |         |          |        |
| #7 · dependabot[bot] opened 18 minutes ago · Bot · 7/9                       |        |        |       |          |            |         |          |        |
| <b>chore(deps-dev): bump eslint-plugin-react-refresh from 0.5.2 to 0.5.7</b> |        |        |       |          |            |         |          |        |
| #6 · dependabot[bot] opened 18 minutes ago · Bot · 7/9                       |        |        |       |          |            |         |          |        |
| <b>chore(deps): bump the react-three group with 3 updates</b>                |        |        |       |          |            |         |          |        |
| #5 · dependabot[bot] opened 18 minutes ago · Bot · 7/9                       |        |        |       |          |            |         |          |        |
| <b>chore(deps): bump gradle-wrapper from 8.14.3 to 9.7.1 in /android</b>     |        |        |       |          |            |         |          |        |
| #4 · dependabot[bot] opened 19 minutes ago · Bot · 7/9                       |        |        |       |          |            |         |          |        |
| <b>chore(deps): bump node from 22-alpine to 25-alpine in /server</b>         |        |        |       |          |            |         |          |        |
| #3 · dependabot[bot] opened 19 minutes ago · Bot · 7/9                       |        |        |       |          |            |         |          |        |

Figura 11 — Dependabot ativo: PRs automáticos de atualização abertos no repositório (revisão contínua de dependências).

## 5. Checklist de conformidade

Legenda:  implementado e executado/verificado ·  não aplicável (justificado)

| #  | Controle                                             | Status                                                                              | Evidência                                                                                                                    |
|----|------------------------------------------------------|-------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|
| 1  | Pipeline CI/CD com gates de segurança                |    | 9/9 jobs aprovados; a 1ª execução foi bloqueada pelo Semgrep (gate funcionando)                                              |
| 2  | SAST — Semgrep                                       |    | evidencias/semgrep.txt : 216 regras, 0 bloqueantes                                                                           |
| 3  | SCA — npm audit                                      |    | npm-audit-antes.txt (5 HIGH) → npm-audit-app.txt (0 HIGH) · npm-audit-server.txt (0)                                         |
| 4  | SCA — Dependabot                                     |    | .github/dependabot.yml , ativo no repositório (execuções Dependabot Updates)                                                 |
| 5  | Secret scanning — Gitleaks                           |    | evidencias/gitleaks-ci.txt : 52 commits, sem vazamento                                                                       |
| 6  | Container — Trivy image + SBOM                       |    | evidencias/trivy-image-ci.txt : 0 vulnerabilidades; SBOM como artefato do run                                                |
| 7  | IaC — Checkov                                        |    | evidencias/checkov.txt e iac-ci.txt : 344 checks, 0 falhas                                                                   |
| 8  | IaC — Trivy config                                   |    | job iac aprovado                                                                                                             |
| 9  | Segredos fora do código (.env.example , .gitignore ) |    | server/.env.example , .gitignore ; git status --ignored mostra .env e users.json ignorados                                   |
| 10 | Criptografia local no mobile                         |  | secureStore.js ; storage verificado sem JWT legível                                                                          |
| 11 | Validação de entrada                                 |  | routes/specs.js + specs.test.js                                                                                              |
| 12 | Rate limit + lockout                                 |  | app.js , lockout.js + auth.test.js                                                                                           |
| 13 | JWT seguro                                           |  | tokens.js + testes alg:none /forjado/expirado/revogado                                                                       |
| 14 | RBAC (3 perfis)                                      |  | rbac.test.js + teste manual com API rodando                                                                                  |
| 15 | Headers/CORS/CSP                                     |  | hardening.test.js ; CSP verificada no navegador                                                                              |
| 16 | Hardening Android                                    |  | Job android : APK gerado e manifest conferido; APK disponível como artefato                                                  |
| 17 | MQTT/TLS                                             |  | Sem IoT no escopo (2.4)                                                                                                      |
| 18 | Dockerfile / compose / K8s seguros                   |  | Checkov 0 falhas                                                                                                             |
| 19 | Logs estruturados                                    |  | evidencias/exemplo-logs.jsonl (logs reais)                                                                                   |
| 20 | Métricas e alertas                                   |  | /metrics com tráfego real; as 9 regras avaliadas ao vivo no painel ( RateLimitDisparando disparou no brute force simulado)   |
| 21 | Dashboard de monitoramento                           |  | Painel embutido em :9464/dashboard/ (print na entrega); Grafana provisionado em infra/grafana/ para produção (requer Docker) |
| 22 | Plano de resposta a incidentes                       |  | RESPOSTA_A_INCIDENTES.md                                                                                                     |
| 23 | STRIDE + DevSecOps                                   |  | Seção 4.1                                                                                                                    |
| 24 | OWASP ASVS / API / Mobile                            |  | Seção 4.2                                                                                                                    |
| 25 | LGPD                                                 |  | Seção 4.3                                                                                                                    |
| 26 | Plano de segurança contínua                          |  | Seção 4.4                                                                                                                    |

## 6. Como reproduzir as evidências

---

```
API: testes de segurança
cd server && npm ci && npm test

API rodando + usuários de demonstração (senhas aleatórias mostradas uma vez)
cp .env.example .env # preencha JWT_SECRET (comando no próprio arquivo)
npm run seed:demo
npm run dev

App no navegador (outra aba)
cd .. && npm ci && npm run dev # botão "Pesquisar concorrência"

Tráfego para logs/dashboards
DEMO_EMAIL=analista@ford-demo.test DEMO_PASSWORD=<senha do seed> npm --prefix server run simulate

Observabilidade completa (Docker)
cd infra && cp .env.example .env && docker compose up -d --build
Grafana: http://127.0.0.1:3001 · Prometheus: http://127.0.0.1:9090/alerts

SAST/IaC local (Python)
pip install semgrep checkov
semgrep scan --config p/owasp-top-ten --config p/javascript --config p/nodejsscan --config .semgrep/ford-rules.yml
checkov -d . --framework dockerfile,kubernetes,github_actions --skip-path workshop
```

Os prints da entrega estão em `docs/cybersecurity/prints/` e foram gerados automaticamente contra o app e a API rodando. O PDF consolidado é `docs/cybersecurity/Sprint3_Cybersecurity_Ford.pdf`.